# Application VAPT

**BY**

## Titan Company Limited

**Application Name** : CELEBRATION SITE TANISHQ
**Tester URL** : https://celebrationsite-preprod.tanishq.co.in/
**Application Owner** : Santhosh Kumar K P
**Application Category** : High
**Environment** : UAT
**Business Name** : Jewellery
**WAF Name** : Indusface (Prod)
**Scan Date** : 11-02-2026
**Digital SPOC** : Santhosh Kumar K P

Confidential

## 1. Scope

The scope of this engagement was to evaluate the security posture of the web applications, identifying threats and vulnerabilities from both unauthenticated and authenticated user perspectives, across various privilege levels. The assessment aimed to uncover flaws in authentication, authorization, access controls, and session management. It provided a comprehensive view of vulnerability, offering mitigation strategies to help the organization meet industry standards and defend against evolving threats.

| IP | Type of Asset | Internal / External |
|---|---|---|
| 10.160.128.125<br>10.160.128.78 | AWS | External |

## 2. Confidentiality

This document contains sensitive and confidential information. It should not be shared, distributed, emailed, faxed, or transmitted electronically without proper authorization. The information within must be handled with the utmost care. Although every effort has been made to ensure the accuracy of the data presented, Titan Company ltd does not assume any responsibility for its completeness, usage, or any conclusions derived from it.

## 3. Executive Summary

A summary of vulnerabilities that have been discovered while performing web application security.

| Critical | High | Medium | Low | Info |
|---|---|---|---|---|
| 2 | 1 | 3 | 2 | 0 |

SEVERITY

Low 2

Medium 3
Critical High Medium Low
Critical 2

High 1

Confidential

# Detailed Report

## Overview Table

| Vulnerability | OWASP Top 10 - 2025 | Severity |
|---|---|---|
| Account Takeover | A07: Identification and Authentication Failures | **Critical** |
| Authentication Bypass (Response Manipulation) | A01: Broken Access Control | **Critical** |
| Rate Limiting on Form Submission | A07-Identification and Authentication Failures | **High** |
| Missing Input Validation | A03: Injection | **Medium** |
| Improper Error Handling | A05: Security Misconfiguration | **Medium** |
| Server Disclosure (Version / Banner Info) | A05: Security Misconfiguration | **Medium** |
| Clear Text Credentials | A02: Cryptographic Failures | **Low** |
| HTTP Methods Allowed (Improperly Configured) | A05: Security Misconfiguration | **Low** |

# 1. Account Takeover

- CWSS Score: **9.5 (Critical)**
- CVSS Score**: 9.8 (Critical)**
- Cyber Security Exposure Score: **Critical**

**Description**:

The application trusts a client-supplied store context parameter to determine the active account session. By modifying this value in backend requests, an attacker can switch into any other store account without authorization, resulting  in complete unauthorized access to the targeted tenant.

**POC:**

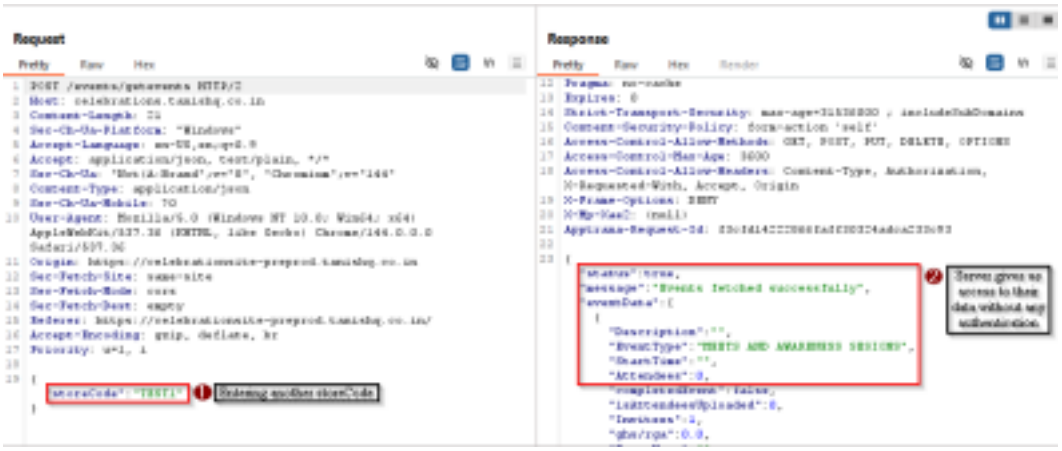
**POC 1: Baseline Response in Burp Suite, logging into the 'TEST' Account**

**POC 2: Browser view of 'TEST' Account**

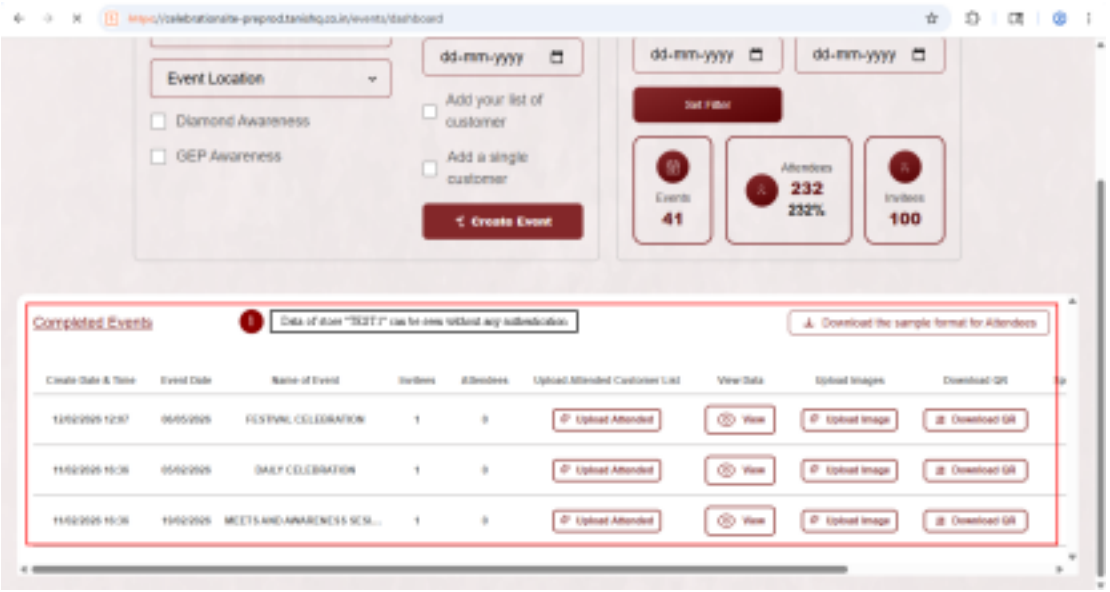
TITANIUM
BE AWARE. STAY SECURE.

Confidential

**POC 3: Modified request in Burp Suite, changing the 'StoreCode' to 'TEST1'**




**POC4: Gained access to the 'TEST1' Account in the browser**




**Mitigation**:

• Enforce strict server-side authorization checks for all user and store context

actions.
• Bind session tokens to specific user identities and tenant scopes. • Never trust client-controlled identifiers for access decisions.
• Implement access control middleware across all sensitive endpoints.

Confidential

## 2. Authentication Bypass (Response Manipulation)

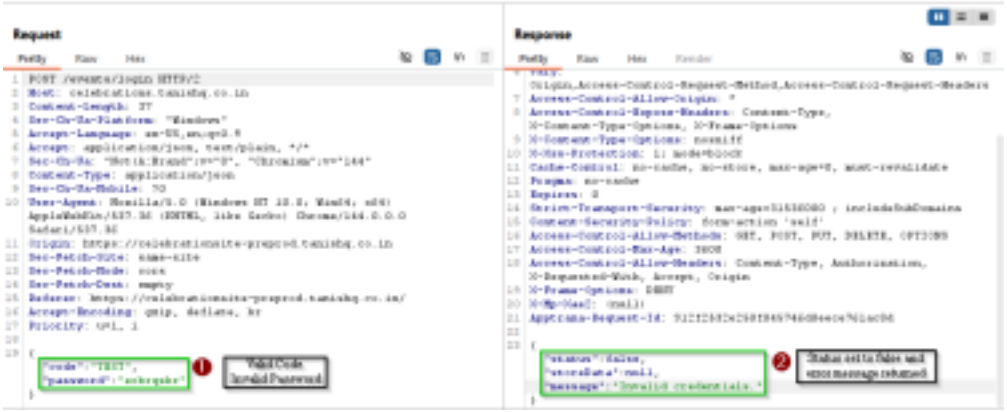
• CWSS Score: **9.3 (Critical)**
• CVSS Score**: 9.6 (Critical)**
• Cyber Security Exposure Score: **Critical**

**Description**:

The application determines authentication success based on client controlled response parameters rather than strictly enforced server-side verification. By intercepting the authentication flow and modifying the response values (such as status flags and store identifiers), it is possible to bypass credential validation and gain access to protected application areas.

**POC**:

**POC 1: Baseline request in Burp Suite for invalid login credentials**

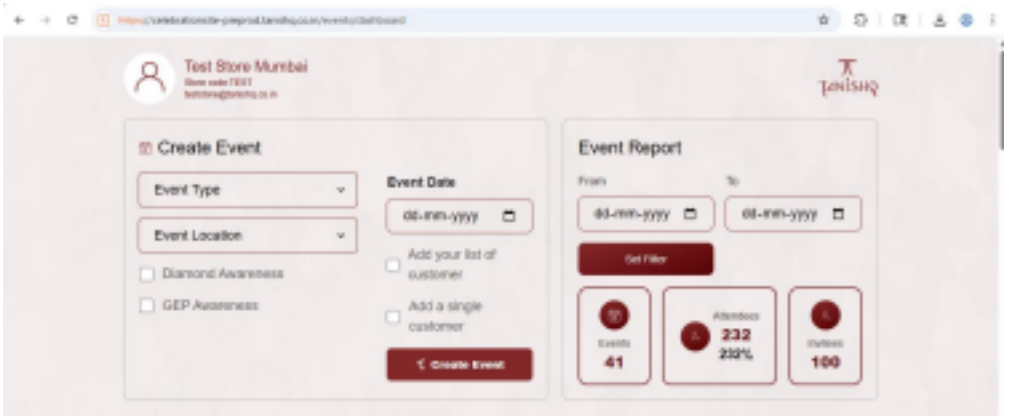



TITANIUM
BE AWARE. STAY SECURE.

Confidential

**POC 2: Response Manipulation in Burp to gain unauthorized access to 'TEST1'**

**POC 3: Successful Auth Bypass in the Browser**




**Mitigation:**

• Perform authentication decisions strictly on the server, not via client controlled flags.

• Issue cryptographically signed session tokens only after credential validation.
• Use signed tokens (JWT/session IDs) validated server-side.
• Authentication success must be determined exclusively server-side.

Confidential

## 3. Rate Limiting on Form Submission

• CWSS Score: **8.2 (High)**
• CVSS Score**: 8.1 (High)**
• Cyber Security Exposure Score: **High**

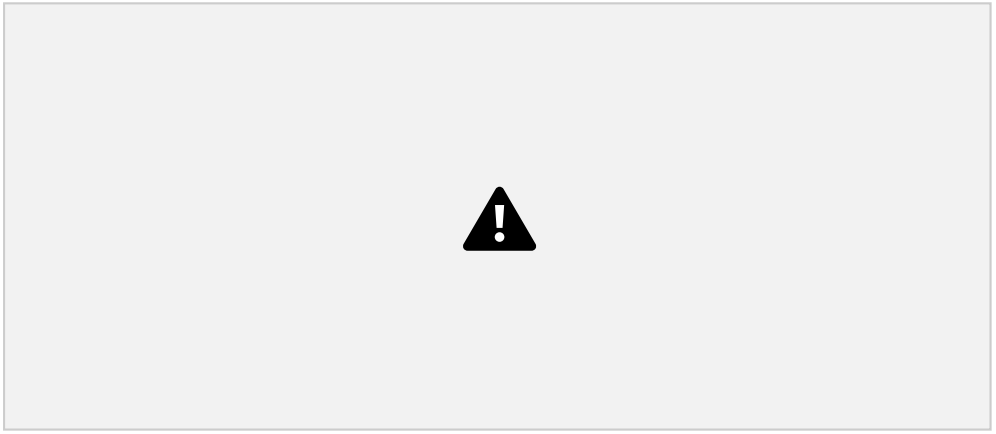
**Description**:

The application does not enforce request throttling or rate limiting on form submission endpoints. Automated tools can repeatedly submit requests in high volumes, all of which are processed successfully by the backend and reflected in the application UI.

**POC**:

**POC 1: Rate Limiting attack on Burp Suite by sending a large amount of requests**

**POC 2: All the requests are shown in the browser**





Confidential

**Mitigation:**

• Apply per-IP and per-user rate limits on all submission endpoints. • Introduce CAPTCHA or challenge-response for abuse-prone forms.
• Log and block automated high-frequency requests.
• Throttle requsts at WAF/load balancer level.

Confidential

## 4. Missing Input Validation

- CWSS Score: **6.5 (Medium)**
- CVSS Score**:** **6.8 (Medium)**
- Cyber Security Exposure Score: **Medium**

**Description**:

The phone number field validation is implemented exclusively on the frontend UI. When requests are intercepted and modified, the backend accepts arbitrary values without enforcing format or content restrictions, indicating missing server-side validation controls.

**POC**:

**POC 1: The Client-side Input Validation is Working**

Confidential

**POC 2: No backend Input Validation, server accepts an invalid input**

**Mitigation:**

- Replicate all validation logic on the backend.
- Reject malformed or unexpected inputs server-side before processing. • Apply strict schema validation for each request field.
- Never rely on UI controls for security enforcement.



## 5. Improper Error Handling

- CWSS Score: **6.2 (Medium)**

• CVSS Score**: 6.5 (Medium)**
• Cyber Security Exposure Score: **Medium**

**Description**:

Multiple input fields rely solely on client-side validation and lack proper server side input constraints. Submitting oversized values (256+ characters) causes backend database operations to fail, resulting in HTTP 500 Internal Server Errors. The application further discloses detailed SQL and Hibernate exception messages in responses.

In addition to the brideName field, the same behavior was observed across multiple user-controlled parameters, including bridetype, event, zipCode, number, and email.

**POC**:

**POC 1: Baseline request in Burp Suite**

Confidential

**POC 2: Entering invalid input in the backend request in Burp Suite**

**POC 3: Internal Server Error 500 in the Browser**

**Mitigation:**

- Enforce strict server-side input length and format validation for all parameters.
- Apply allow-list validation (expected size, type, pattern) before database operations.
- Replace detailed exception outputs with generic user-safe error messages.
- Log full errors internally only and disable stack traces in production.
- Implement centralized error handling to prevent unhandled failures

Confidential

## 6. Server Disclosure (Version / Banner Info)

- CWSS Score: **5.8 (Medium)**

- CVSS Score: **5.3 (Medium)**
- Cyber Security Exposure Score: **Medium**

**Description**:

Certain error and malformed request responses include HTTP headers that disclose backend infrastructure details, specifically identifying the use of AWS Elastic Load Balancer along with version information (awselb/2.0). This reveals internal technology stack components intended to remain hidden from external users.

**POC**:

**POC 1: Burp Suite request with exposed infrastructure name & version**

**Mitigation:**

- Configure AWS ELB / reverse proxy to use custom error pages
- Suppress default infrastructure headers at LB level
- Route all errors through application error handler
- Normalize headers across success + error responses

Confidential

## 7. Clear-Text Credentials

- CWSS Score: **4.4 (Low)**
- CVSS Score**: 4.3 (Low)**
- Cyber Security Exposure Score: **Low**

**Description**:

The application transmits user authentication credentials in plaintext within the HTTPS request body during login operations. While protected by TLS in transit, the credentials are not additionally obfuscated or tokenized at the application layer.

**POC**:

**POC 1: Cleartext Credentials in Burp Suite Request**

**Mitigation:**

- Use HTTPS (TLS encryption).
- Avoid logging sensitive credentials.
- Store passwords using strong hashing algorithms.
- Implement secure key management.



## 8. HTTP Methods Allowed (Improperly Configured)

- CWSS Score: **4.2 (Low)**
- CVSS Score**:** **4.0 (Low)**
- Cyber Security Exposure Score: **Low**

**Description**:

Unnecessary HTTP methods such as PUT, DELETE or OPTIONS may be enabled on the server. If not properly restricted, these methods may allow attackers to manipulate resources or perform reconnaissance.

**POC**:

**POC 1: Burp Suite Reponse with improper HTTP Method Configuration**

**Mitigation:**

- Disable unused HTTP methods at server and proxy level.
- Allow only required verbs per endpoint (GET, POST, etc.).
- Return 405 for disallowed methods.
- Audit method exposure during security testing.